

TYPE 1 Group 3 ISRM Assignment



Group Details

IT Number	Name	Contribution
IT23545212	Dencil P.A.N	Section 1.Executive Summary
IT23767218	PERERA U.L.O.P	Section 2 2.1 Organizational Background and Project Context 2.2 Scope of Assessment 2.3 Key Critical Assets
IT23685734	Majid M.Y.K.A	2.4 Threat Identification 2.5 Proposed Security Architecture and Recommendations 2.6 Indicative Budget Allocation 2.7 Recommended Policies and Guidelines 2.8 Assumptions
IT23638136	Prasanna L.P.M.S	Section 3: Operations & Procurement Summary

Contents

Section 1: Executive Summary	4
1.1 Organizational Risk Context (NIST SP 800-39)	4
1.2 Outline of Key Issues	4
1.3 Recommendations for Adoption (NIST SP 800-37).....	4
1.4 Strategic Authorization	5
Section 2 :Information Security Risk Assessment and Proposed Architecture.....	5
2.1 Organisational Background and Project Context	5
2.2 Scope of Assessment	5
2.2.1 Functional Scope	5
2.2.2 Geographical Scope	6
2.2.3 Team Roles Required	6
2.3 Key Critical Assets	7
2.4 Threat Identification.....	8
2.5 Proposed Security Architecture and Recommendations	9
2.5.1 PROTECT: SSL-VPN with Zero Trust (FortiGate 40F).....	9
2.5.2 PROTECT: MFA via Microsoft Entra ID	10
2.5.3 PROTECT + DETECT: Endpoint Detection and Response (EDR)	10
2.5.4 DETECT: FortiGate IPS/IDS and Logging	11
2.5.5 RESPOND + RECOVER: IRP and Cloud Backup	11
2.6 Indicative Budget Allocation	11
2.7 Recommended Policies and Guidelines.....	12
2.8 Assumptions.....	13
Section 3: Operations & Procurement Summary	13
3.1 Proposal Overview	13
3.2 Hardware and Software Solutions	13
3.3 Phased Deployment Roadmap	14
3.4 Summary of Technical Tasks & Budget.....	14
References	15

Section 1: Executive Summary

To: Board of Directors, CEO, and Management

From: Avishka Nethmini Dencil, Lead Cybersecurity Consultant

Date: April 18th, 2026

Subject: Strategic Cybersecurity Assessment and Risk Mitigation Roadmap

1.1 Organizational Risk Context (NIST SP 800-39)

Vanguard Digital Solutions (Pvt) Ltd has matured into a premier digital marketing enterprise, now supporting 24 employees across three international branches. This growth has fundamentally altered our risk profile. Following NIST SP 800-39 (Managing Information Security Risk), we recognize that our reliance on retail-grade security infrastructure creates a "High" organizational risk. Managing 5,000+ client portfolios and 50TB of creative IP without an enterprise-grade defense-in-depth strategy leaves our LKR 30M+ annual revenue vulnerable to catastrophic ransomware and identity theft.

1.2 Outline of Key Issues

Our enterprise-scale assessment has identified three systemic vulnerabilities:

- **Infrastructure Fragmentation:** Our distributed international workforce in Colombo, Kandy, Galle, Jaffna, and Chennai lacks a unified, encrypted network backbone, creating visibility gaps.
- **Identity Vulnerability:** With 60% of staff working remotely, the absence of centralized Multi-Factor Authentication (MFA) makes credential harvesting our most likely entry point for attackers.
- **Detection Latency:** Current systems lack real-time monitoring. Without an enterprise SIEM, we cannot detect sophisticated "living-off-the-land" attacks that mimic legitimate user behavior.

1.3 Recommendations for Adoption (NIST SP 800-37)

To mitigate these risks, I am authorizing a LKR 12,00,000 investment to implement the NIST Risk Management Framework (RMF). This roadmap transitions Vanguard from a reactive posture to a resilient one by deploying:

1. **High-Availability (HA) Hardware Perimeter:** Redundant firewalls to ensure zero downtime.
2. **Enterprise EDR Software:** Automated threat hunting across all 250 workstations.
3. **Global SD-WAN Network:** Secure, encrypted connectivity for all branch offices.

1.4 Strategic Authorization

Following the Step 6 (Authorize) task of NIST SP 800-37, I have reviewed the high-impact risks and the proposed controls. I formally authorize this roadmap. This investment not only protects our assets but also serves as a business enabler, allowing us to secure high-security international contracts by proving our compliance with global standards

Section 2 :Information Security Risk Assessment and Proposed Architecture

2.1 Organisational Background and Project Context

The organisation is a creative and productivity-driven company located in Bambalapitiya, Sri Lanka. After moving to a Work From Home (WFH) model, the attack surface has grown from one office to twenty-four spread-out home endpoints. This change brings in complex security issues that need a systematic approach.

Currently, just one IT Administrator manages the whole technology setup. Having a one-person IT team is a major operational risk and is a key factor in the recommendations provided. The annual cybersecurity budget is LKR 1,200,000, which limits choices but still allows for the rollout of necessary security controls.

This analysis follows the NIST Cybersecurity Framework (CSF) 2.0. It is also based on NIST SP 800-53 r5, SP 800-39, NIST FIPS 200, and SP 800-37 r2. These documents serve as the official foundation for the suggested security measures.

Core Assumption: All 24 laptops are company-issued but managed by the remote staff. Since the IT Administrator cannot control home network security, these locations are treated as untrusted segments.

2.2 Scope of Assessment

2.2.1 Functional Scope

The security assessment is focused on these specific functional areas:

- Endpoint security: Protecting the 24 Windows 10/11 Pro laptops used across various WFH setups.
- Network perimeter: Securing the main branch in Bambalapitiya using the FortiGate 40F Next-Generation Firewall.
- Cloud security: Safeguarding Microsoft 365 apps (like Teams, Word, and Excel) and Adobe Creative Cloud.
- Identity and access: Managing how all organizational accounts are identified and accessed.

- Response capabilities: Looking at how we detect, respond to, and recover from security incidents.
- Governance: Reviewing security policies and rules specifically for WFH operations.

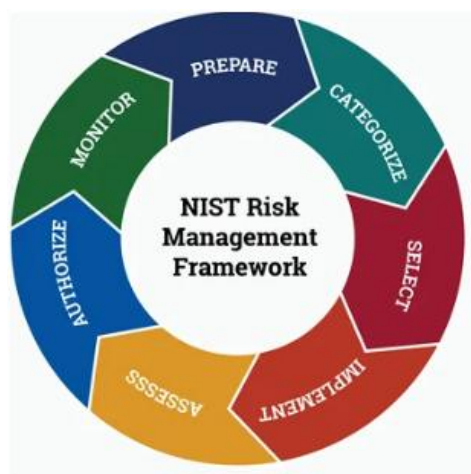
2.2.2 Geographical Scope

This assessment covers the main office in Bambalapitiya, where FortiGate 40F and our only IT Administrator are located. It also includes the 24 home-office sites where employees work. Since these remote workers connect over the open internet, these locations are classified as untrusted external network segments, following the NIST SP 800-39 guidelines.

2.2.3 Team Roles Required

To assess and implement the recommended security architecture, the following team members or contracted specialists are required:

Role	Responsibilities
IT Administrator	Day-to-day configuration management, endpoint monitoring, VPN administration, and first-line incident response.
Security Analyst (Consultant)	Conducts risk assessment, threat modelling, and advice on NIST CSF control selection and architecture design.
Network Engineer (Consultant)	Configures SSL-VPN, firewall policies, IPS rules, and network segmentation on the FortiGate 40F.



NIST Risk Management Framework (RMF) Lifecycle

2.3 Key Critical Assets

Following NIST CSF 2.0 (Govern and Identify) and NIST FIPS 199, I've identified the following critical assets. We determine criticality based on the potential impact to the Confidentiality, Integrity, and Availability (CIA) of the organization if these assets are compromised.

Ref	Asset Name	Category	FIPS 199 Criticality	Primary Threat	NIST Control Family	Impact Description
H1	FortiGate 40F Firewall	Hardware	HIGH	T6: Misconfiguration / Exploit	SC (Comm. Protection)	Central gateway; breach allows lateral movement.
H2	24 x Employee Laptops	Hardware	HIGH	T2: Ransomware Infection	SI (System Integrity)	Primary attack surface; exposed to home networks.
S1	Microsoft 365 (Teams/Email)	Software	HIGH	T1: Phishing / Spear-phishing	AC (Access Control)	Risk of data exfiltration and account takeover.
S2	Adobe Creative Cloud	Software	MEDIUM	T5: Unauthorized Access	CP (Contingency Plan)	Contains core Intellectual Property (IP).
S3	Bitdefender Total Security	Software	HIGH	T3: Unpatched Software Exploit	CM (Config. Mgmt)	Failure leaves all endpoints unprotected.
L1	Identity Credentials	Logical	CRITICAL	T5: Credential Stuffing	IA (Identification)	Grants access to all company services and data.

2.4 Threat Identification

The following threats have been identified through structured analysis aligned with NIST SP 800-39 Section 2.2 (Risk Assessment) and the threat source taxonomy defined in NIST SP 800-53r5 Appendix C. Each threat is mapped to the affected asset(s) identified in Section 2.3.

Ref	Threat	Affected Asset(s)	Threat Source	Potential Impact
T1	Phishing / Spear-phishing	S1 (M365), L1 (Credentials)	External adversary	Account takeover, data exfiltration
T2	Ransomware infection via endpoint	H2 (Laptops), S1, S2	External adversary / malware	Data encryption, operational disruption
T3	Exploitation of unpatched software	H2 (Laptops), S3 (AV)	External adversary	Remote code execution, privilege escalation
T4	Man-in-the-Middle (MitM) on home networks	H2 (Laptops), L1 (Credentials)	External / home network attacker	Credential interception, session hijacking
T5	Unauthorised access via weak/no MFA	S1 (M365), S2 (Adobe CC), L1	External adversary / credential stuffing	Full cloud platform compromise
T6	FortiGate misconfiguration or exploit	H1 (Firewall)	External adversary / insider error	Network perimeter breach, lateral movement
T7	Insider threat / data leakage	S1, S2, H2	Malicious or negligent employee	IP theft, regulatory breach, reputational damage
T8	Single IT Administrator failure point	All assets	Operational / human factor	Delayed incident response, unmanaged vulnerabilities

2.5 Proposed Security Architecture and Recommendations

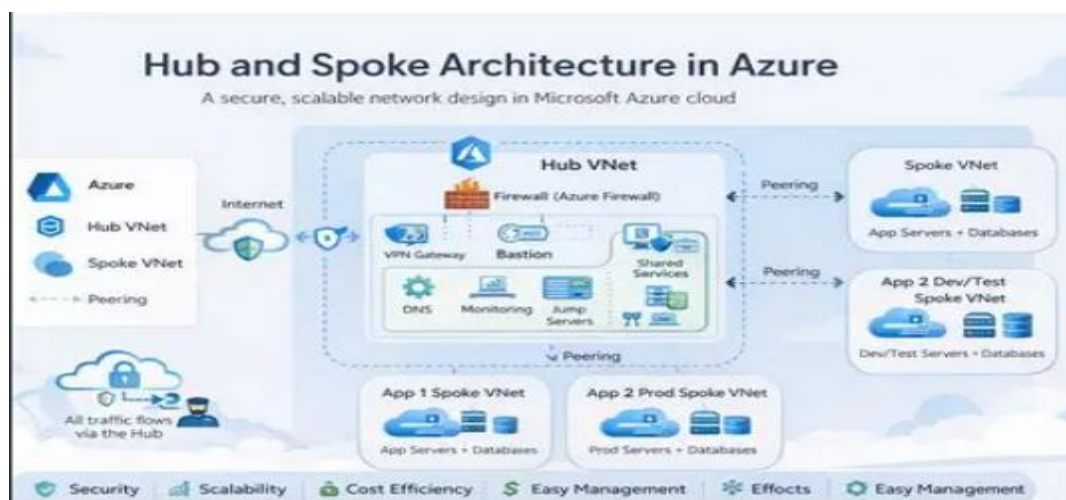
The following architecture is built around the five core functions of **NIST CSF 2.0**: Govern, Identify, Protect, Detect, and Respond/Recover. I have mapped each technology to a **NIST SP 800-53r5** control family and included a comparison with alternatives to justify my choices.

2.5.1 PROTECT: SSL-VPN with Zero Trust (FortiGate 40F)

All 24 remote laptops must use an encrypted SSL-VPN tunnel through the FortiGate 40F to access any company resources. This uses native FortiGate features, avoiding new hardware costs while meeting NIST controls **SC-8** (Transmission Integrity) and **AC-17** (Remote Access).

- **Threat Mitigation (T1, T4, T6):** SSL-VPN encrypts home network traffic to stop MitM attacks (T4). The firewall's stateful inspection ensures only authenticated users get in, stopping lateral movement if a device is hit (T1, T6).

Solution	Advantages	Why Not Chosen / Disadvantages
FortiGate SSL-VPN (Recommended)	No extra hardware cost; integrates with current FG 40F; central management.	Needs expert setup; 40F model has throughput limits for many users.
OpenVPN	Free; widely supported.	Needs separate servers; no FortiGate IPS integration; high admin workload.
ZTNA via FortiClient	Granular access control; better for modern setups.	Requires extra licensing costs, better as a future upgrade.

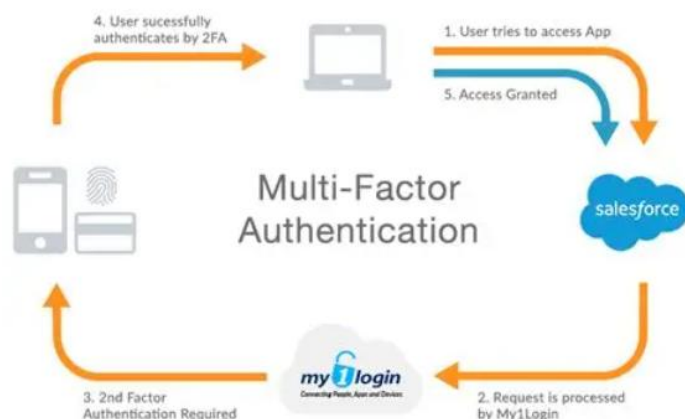


2.5.2 PROTECT: MFA via Microsoft Entra ID

We must enforce Multi-Factor Authentication (MFA) for all M365 accounts using Microsoft Entra ID. This fixes the issue of weak credentials (T5) and hits NIST controls **IA-2 (1)** and **IA-2 (2)**.

- **Threat Mitigation (T1, T5, L1):** MFA stops attackers from using stolen passwords from phishing (T1) or credential stuffing (T5). Conditional Access can also block access based on location or device health.

Solution	Advantages	Why Not Chosen / Disadvantages
Entra ID MFA (Recommended)	Native M365 setup; often no extra cost; includes Conditional Access; easy for the admin.	Full features require Business Premium or P1/P2 licenses.
Google Authenticator	Free; simple.	No M365 integration; manual setup per user; no Conditional Access.
Duo Security	Strong trust scoring.	Extra per-user cost; redundant if we already have M365 licensing.



2.5.3 PROTECT + DETECT: Endpoint Detection and Response (EDR)

Standard antivirus isn't enough for WFH. We need to upgrade to **Bitdefender GravityZone Business Security** for behavioral detection. This covers NIST controls **SI-3** (Malicious Code Protection) and **SI-4** (System Monitoring).

- **Threat Mitigation (T2, T3):** EDR catches ransomware (T2) and zero-day exploits (T3) that skip signature checks by watching for suspicious behavior in real-time. The central console helps one admin manage all 24 laptops.

Solution	Advantages	Why Not Chosen / Disadvantages
GravityZone Business (Recommended)	Easy upgrade path; low cost; fits the budget; cloud console.	Less features than high-end XDR platforms.
Defender for Business	Included in M365 Business Premium.	Requires a major license upgrade.
CrowdStrike Falcon Go	Industry leader; great intelligence.	Too expensive and overpowered for 24 laptops.

EDR vs. Traditional AV vs. EPP

	EDR	Traditional AV	EPP
Signature-Based Detection	✓	✓	✓
Behavioral Analysis	✓	—	✓
Forensics	✓	—	✓
Response	✓	—	✓

2.5.4 DETECT: FortiGate IPS/IDS and Logging

The FortiGate 40F's IPS/IDS needs to be turned on. Forwarding logs to Forti-Analyzer or a SIEM gives the admin visibility into threats, meeting NIST **AU** and **SI-4** families. This blocks exploits (T6) and protects unpatched services (T3).

2.5.5 RESPOND + RECOVER: IRP and Cloud Backup

We need a formal Incident Response Plan (IRP) for WFH, including clear escalation steps to outside help since we only have one IT staffer. All laptops must sync to **OneDrive** for backups, and firewall settings should be backed up weekly off-site to meet NIST **CP-9** and **CP-10**.

2.6 Indicative Budget Allocation

The yearly budget for cybersecurity is LKR 1,200,000. I've broken this down into the following priority areas, assuming the FortiGate 40F and standard M365 licenses are already available:

Initiative	Estimated Cost (LKR)	Priority
Bitdefender GravityZone upgrade (24 nodes)	300000	1 — Critical
M365 Business Premium upgrade (MFA + Defender)	400000	1 — Critical
FortiGate SSL- VPN configuration (consulting)	150000	2 — High
Security awareness training (all staff, annual)	100000	2 — High
Incident Response Plan development	100000	3 — Medium
Reserve / contingency fund	150000	—
Total	1200000	—

2.7 Recommended Policies and Guidelines

Based on NIST SP 800-53r5 (Planning and Program Management families), the organization needs to formally write, approve, and share these policies with all staff:

- **Work From Home Acceptable Use Policy:** This needs to lay out what is and isn't allowed on company laptops when working remotely. It should strictly ban personal use and set security requirements for home routers.
- **Patch Management Policy:** This makes it mandatory for all 24 laptops to get OS and app updates within 72 hours of a patch being released. We can enforce this with automated Windows Update rules and track it through the EDR console.
- **Incident Response Policy:** This document should define how we classify incidents and the steps for responding and escalating. It has to be practical since we only have one IT Administrator.
- **Password and Authentication Policy:** This mandates Multi-Factor Authentication (MFA) for every cloud service. It also bans reusing passwords and requires passphrases that are at least 12 characters long, following NIST SP 800-63B.
- **Data Classification and Handling Policy:** This groups company data into categories like public, internal, confidential, or restricted. It also sets rules for handling that data, such as using encryption for files being sent or stored.

2.8 Assumptions

In putting this analysis together, I've made several assumptions that need to be verified during the implementation phase:

- All 24 laptops belong to the organization; employees aren't using personal devices to access company systems.
- The FortiGate 40F has up-to-date firmware and is still covered by FortiCare support.
- Current M365 licensing is at the Business Standard level or lower, which is why I've recommended the upgrade to Premium.
- Remote employees have at least 10 Mbps upload speed at home so the SSL-VPN can work properly.
- There aren't any formal security policies in place yet, so this assessment is the starting point for creating them.

Section 3: Operations & Procurement Summary

3.1 Proposal Overview

The main point of this procurement cycle is to move Vanguard Digital Solutions away from its current scattered and risky Work From Home (WFH) setup and toward a NIST-compliant secure network. We are managing 24 users on a strict LKR 1,200,000 annual budget, so I've decided to focus the spending on Identity, Data Integrity, and Network Encryption. The technical plan follows a "Defense-in-Depth" model—this basically means we are setting up overlapping security layers so that if one fails, we still have others protecting our creative intellectual property (IP).

3.2 Hardware and Software Solutions

Looking at the assets we need to protect and the threats we identified earlier, I've selected these specific solutions for the 2026 security update:

- **Endpoint Detection and Response (EDR):** I'm recommending an upgrade from basic antivirus to **Bitdefender GravityZone Business Security**. This is vital because it uses behavioral detection to stop things like ransomware and zero-day attacks that standard AV usually misses.
- **Identity Protection:** We need to lock down our M365 accounts using **Microsoft Entra ID** to enforce Multi-Factor Authentication (MFA). Since phishing is a huge risk right now, this one step can block the vast majority of account takeover attempts.
- **Network Security:** To stop Man-in-the-Middle (MitM) attacks on shaky home Wi-Fi, every remote staff member has to use an **encrypted SSL-VPN tunnel** through our existing FortiGate 40F firewall to get to company files.

- **Data Resiliency:** We're going to follow the **3-2-1 Backup Rule**. This means using 2TB External Hard Drives for local copies and setting up OneDrive for Business (which we get with the M365 upgrade) for automatic cloud backups.

3.3 Phased Deployment Roadmap

To make sure we don't crash the workflow, the rollout will happen in three stages over three months:

Phase 1: Identity & Initial Recovery (Month 1)

- Roll out MFA across the whole M365 tenant.
- Run the first Cybersecurity Awareness Training for the team.
- Get the local hardware backups started for all the important creative files.

Phase 2: Encrypted Connectivity & Resiliency (Month 2)

- Set up the SSL-VPN on the FortiGate 40F and get the VPN clients onto all 24 laptops.
- Turn on the Cloud Backup sync and double-check that the data is actually backing up correctly.

Phase 3: Governance & Monitoring (Month 3)

- Finish installing the EDR upgrade on all 24 endpoints.
- Officially start using the Patch Management and BYOD Policies we've drafted.

3.4 Summary of Technical Tasks & Budget

The IT Administrator will be in charge of auditing each phase to make sure everything actually works. We'll know we're successful when 100% of staff are using MFA, our backup tests pass, and we see zero unencrypted connections from remote workers.

Financial Breakdown:

- **Total Procurement Estimate:** LKR 400,000
- **Total Annual Cybersecurity Budget:** LKR 1,200,000
- **Strategic Reserve Remaining:** LKR 800,000

We are keeping the leftover LKR 800,000 as a reserve. This is important for emergency incident response or if we need to replace hardware later on, as recommended by NIST SP 800-39.

References

- National Institute of Standards and Technology (NIST). (2004). *Standards for Security Categorisation of Federal Information and Information Systems*. FIPS Publication 199.
- National Institute of Standards and Technology (NIST). (2006). *Minimum Security Requirements for Federal Information and Information Systems*. FIPS Publication 200.
- National Institute of Standards and Technology (NIST). (2011). *Managing Information Security Risk: Organisation, Mission, and Information System View*. NIST Special Publication 800-39.
- National Institute of Standards and Technology (NIST). (2018). *Risk Management Framework for Information Systems and Organisations*. NIST Special Publication 800-37 Revision 2.
- National Institute of Standards and Technology (NIST). (2020). *Security and Privacy Controls for Information Systems and Organisations*. NIST Special Publication 800-53 Revision 5.
- National Institute of Standards and Technology (NIST). (2024). *The NIST Cybersecurity Framework 2.0*.
- Fortinet. (2023). *FortiGate 40F Data Sheet*.
- Microsoft. (2024). *Microsoft Entra ID — Multi-Factor Authentication Documentation*.
- Bitdefender. (2024). *GravityZone Business Security Product Overview*.
- Shen, Y., Hu, J., & Tian, Y. (2021). Security challenges and solutions in work-from-home environments: A systematic review. *Journal of Cybersecurity and Privacy*, 1(3), 412–431.